

CONFIDENTIAL — INTERNAL USE ONLY

INCIDENT RESPONSE REPORT

Web Application SQL Injection Leading to Domain Compromise via DCSync

Corvallen Systems Inc.

Incident ID: CSI-IR-2026-031

Prepared by: Corporate Information Security — Incident Response Team

Report Date: June 27, 2026

Report Version: 1.0 — Final

Classification: Confidential — Restricted Distribution

1. Executive Summary

On June 18, 2026, Corvallen Systems Inc. ("the Company") detected anomalous directory replication activity originating from a standard member server rather than a Domain Controller. Investigation determined that an external attacker had compromised the Company's customer-facing web application through a SQL injection vulnerability, pivoted to underlying Linux infrastructure using credentials recovered from the database, escalated privileges through a misconfigured SUID binary, established persistence via a scheduled cron job, moved laterally to a domain-joined Windows host over Remote Desktop Protocol using reused credentials, and ultimately abused a misconfigured Active Directory access control list to perform a DCSync attack, extracting password hashes for all domain accounts, including the krbtgt account.

The IR team contained the incident within 3 hours of the triggering alert, disabled the compromised accounts, isolated affected hosts, and reset credentials domain-wide, including two rounds of krbtgt password resets to invalidate any forged Kerberos tickets. No evidence of ransomware deployment or data destruction was identified; however, the attacker obtained the means to impersonate any domain account, representing a critical exposure.

Key Findings

- Initial access was achieved through an unauthenticated SQL injection vulnerability in a customer portal search parameter, allowing extraction of the application database, including a table containing plaintext SSH credentials for a Linux application server.
- Password reuse between the extracted application-database credential and an operating-system account allowed direct SSH access to the underlying Linux server.
- A custom administrative script installed with the SUID bit set and owned by root allowed the attacker to escalate from a low-privilege shell to root.
- Persistence was established via a cron job disguised as a routine maintenance task, re-establishing outbound access at regular intervals.
- Credentials for a domain service account, found in a configuration file on the Linux host, were reused to authenticate over RDP to a domain-joined Windows server.
- That service account was a member of a group that had been granted Replicating Directory Changes / Replicating Directory Changes All rights on the domain object through a historical, undocumented ACL change, enabling a full DCSync attack.
- No evidence of ransomware, data destruction, or exfiltration of customer data beyond the initial application database was identified.

2. Incident Classification & Scope

Incident Category: External intrusion — web application exploitation leading to domain compromise

Severity Rating: Critical (domain-wide credential material exposed)

Confidentiality Impact: High (application database and domain password hashes)

Integrity Impact: High (ability to forge authentication for any domain account)

Availability Impact: None observed

Systems Affected

Asset	Role in Incident
Customer portal web application	Initial access vector — SQL injection
Application database (PostgreSQL)	Source of leaked SSH credentials
app-lnx-07 (Linux app server)	SSH access, privilege escalation, cron persistence
svc-winrm domain service account	Reused credential for RDP lateral movement
win-app-12 (domain-joined Windows server)	RDP lateral movement target; staging point for DCSync
Active Directory domain	DCSync attack target; all account hashes exposed

3. Timeline of Events

All times are local to Corvallen Systems' primary data center (Eastern Time).

Date / Time	Event
2026-06-15 02:11	Automated scanning traffic against the customer portal begins from a single external IP (later attributed to the intrusion)
2026-06-15 03:40	Attacker identifies and confirms a SQL injection vulnerability in the portal's account-search parameter
2026-06-15 04:05	Attacker extracts application database contents, including a legacy table storing plaintext SSH credentials for app-lnx-07
2026-06-15 04:22	Attacker authenticates over SSH to app-lnx-07 using the recovered credentials
2026-06-15 05:10	Attacker discovers and abuses a root-owned SUID binary to obtain a root shell (privilege escalation)
2026-06-15 05:30	Attacker installs a cron job disguised as a log-rotation task to re-establish outbound access every 6 hours (persistence)
2026-06-16 – 2026-06-17	Attacker conducts internal reconnaissance from app-lnx-07; harvests configuration files, discovering domain service-account credentials
2026-06-17 22:47	Attacker authenticates via RDP to win-app-12 using the recovered service-account credentials (lateral movement)
2026-06-18 00:15	Attacker enumerates the service account's group memberships and identifies replication rights granted via a misconfigured ACL
2026-06-18 00:31	Attacker executes a DCSync request against a Domain Controller, extracting password hashes for all domain accounts
2026-06-18 00:34	Domain Controller security event log records a directory-replication request from a non-DC source; SIEM correlation rule fires
2026-06-18 00:52	SOC analyst escalates the alert to the IR team
2026-06-18 01:40	IR team disables the compromised service account and isolates win-app-12 and app-lnx-07 from the network (containment)
2026-06-18 03:00	Cron persistence mechanism identified and removed from app-lnx-07; SUID misconfiguration reverted
2026-06-18 – 2026-06-19	Domain-wide credential reset performed, including two sequential krbtgt password resets
2026-06-27	Final incident report completed

4. Full Attack Chain — Detailed Narrative

4.1 Initial Access — SQL Injection

The attacker identified an unauthenticated SQL injection vulnerability in a search parameter of the Company's customer-facing web portal. The parameter was concatenated directly into a backend SQL query without sanitization or parameterization, allowing the attacker to manipulate query logic and extract data beyond the intended scope of the search function. Using this vulnerability, the attacker enumerated database tables and extracted the full contents of a legacy table that had been used years earlier to store infrastructure credentials for internal use by developers, including a plaintext SSH username and password for the Linux server app-lnx-07.

4.2 Credential Reuse and SSH Access

The recovered credential remained valid on the operating system account of app-lnx-07 despite the account no longer being in active developer use, a result of the credential never having been rotated after the application database migration. The attacker authenticated directly over SSH using this credential, obtaining an interactive shell as a low-privileged local user.

4.3 Privilege Escalation — SUID Misconfiguration

Enumeration of the host revealed a custom administrative shell script, owned by root, with the SUID bit set. The script had originally been created to allow a low-privileged monitoring account to restart a specific service, but because it was implemented as a shell script with the SUID bit applied and did not adequately restrict its own execution environment, it could be manipulated to execute arbitrary commands with root privileges. The attacker leveraged this misconfiguration to obtain a fully privileged root shell.

4.4 Persistence — Cron Job

With root access established, the attacker created a cron job disguised as a routine log-rotation task. The job executed at six-hour intervals and re-established outbound connectivity to attacker infrastructure, ensuring continued access even if the original SSH session was terminated or the leaked credential was rotated.

4.5 Internal Reconnaissance

Over the following two days, the attacker reviewed configuration files, shell history, and cached credentials on app-lnx-07 as part of internal reconnaissance. This activity surfaced a configuration file used by an internal automation tool, which contained credentials for a domain service account (svc-winrm) used to support remote administration of Windows infrastructure.

4.6 Lateral Movement — RDP to Domain-Joined Host

The attacker used the recovered service-account credentials to authenticate via Remote Desktop Protocol to win-app-12, a domain-joined Windows server. Because the account was a valid domain identity with interactive logon rights, this authentication did not initially generate a high-severity alert.

4.7 Privilege Escalation — DCSync via Misconfigured ACL

From win-app-12, the attacker enumerated the effective Active Directory permissions of the svc-winrm account and its group memberships. This enumeration revealed that the account belonged to a group which had, through a historical and undocumented delegation change, been granted the Replicating Directory Changes and Replicating Directory Changes All permissions on the domain object — rights normally reserved for Domain Controllers and a small number of tightly controlled service accounts. Using these rights, the attacker issued a

directory replication request directly to a Domain Controller, impersonating replication traffic and extracting NTLM password hashes for all domain accounts, including built-in and service accounts.

4.8 Detection

The Domain Controller's security event log recorded a directory-replication request originating from a source other than a recognized Domain Controller. A SIEM correlation rule designed to detect this pattern triggered an alert, which was escalated to the IR team within 18 minutes.

4.9 Attack Chain Summary

SQL Injection in Web Portal → Database Extraction (Leaked SSH Credential) → SSH Access to Linux Host → SUID Binary Abuse (Root Privilege Escalation) → Cron-Based Persistence → Internal Reconnaissance (Config File Credential Discovery) → RDP Lateral Movement to Domain-Joined Windows Host → AD ACL Enumeration → DCSync (Domain-Wide Hash Extraction).

5. Detection & Incident Response Actions

5.1 Detection

Detection occurred at the final stage of the attack chain, triggered by a SIEM correlation rule monitoring for directory-replication requests (DsGetNCChanges) issued from hosts not recognized as Domain Controllers. No earlier stage of the intrusion — the SQL injection, SSH access, privilege escalation, or RDP lateral movement — generated an alert prior to this point.

5.2 Containment

- Disabled the svc-winrm domain service account and terminated all active sessions.
- Isolated app-lnx-07 and win-app-12 from the network pending forensic imaging.
- Blocked the source IP address associated with the intrusion at the perimeter firewall and WAF.
- Placed the customer portal's affected endpoint behind emergency WAF rules pending a code-level fix.

5.3 Eradication

- Removed the malicious cron job and reverted the SUID misconfiguration on app-lnx-07.
- Rotated all credentials present in the compromised configuration file and the legacy application-database credential table.
- Removed the excessive replication rights from the affected AD group following validation of legitimate access requirements.
- Performed two sequential krbtgt password resets, spaced according to standard guidance, to invalidate any Kerberos tickets forged using extracted material.

5.4 Recovery

- Restored app-lnx-07 and win-app-12 to service following validation that no additional persistence mechanisms remained.
- Domain-wide password reset completed for all accounts whose hashes were exposed in the DCSync extraction.

5.5 Communication

- Internal stakeholders notified: CISO, IT infrastructure leadership, and executive leadership, within 4 hours of confirmed domain compromise.
- Legal and Compliance engaged to assess notification obligations given the scope of exposed authentication material.

6. Impact Assessment

Impact Area	Summary
Confidentiality	Application database contents and password hashes for all domain accounts were exposed
Integrity	Attacker held the technical means to forge authentication for any domain account until remediation completed
Availability	No disruption to production services; brief planned downtime during credential resets
Data	No evidence of customer PII exfiltration beyond the initial application database extraction
Operational	Two Linux/Windows hosts isolated for approximately 24 hours during forensic review

Because the DCSync attack exposed password hash material for the entire domain, the incident was classified as critical regardless of the absence of observed follow-on abuse (e.g., ransomware or data destruction), given the difficulty of fully ruling out undetected use of the extracted hashes prior to containment.